

# PROPOSAL TEKNIS

---

## Sistem Informasi Lost & Found IPB dengan Implementasi Protokol Keamanan Informasi

---

**Mata Kuliah** : Keamanan Informasi (KOM1315)

**Semester** : Genap 2025/2026

**Program Studi**: Ilmu Komputer, IPB University

**Tanggal** : Mei 2026

**Kelompok 2** :

- Syafiq Syadidul Azmi (G6401231075)
  - Muhammad Faqih (G6401231081)
  - Luqman Fadillah Santoso (G6401231136)
- 

## DAFTAR ISI

1. [Latar Belakang](#)
  2. [Deskripsi Sistem](#)
  3. [Identifikasi Aset](#)
  4. [Analisis Ancaman dan Kerentanan](#)
  5. [Arsitektur Keamanan yang Diusulkan](#)
  6. [Modul Kriptografi](#)
  7. [Stack Teknologi](#)
  8. [Rencana Implementasi](#)
  9. [Tim Pengembang](#)
- 

## 1. Latar Belakang

Lingkungan kampus IPB University sebagai institusi pendidikan tinggi dengan ribuan civitas akademika aktif setiap harinya rentan terhadap kejadian kehilangan barang. Saat ini, penanganan barang hilang dan temuan di lingkungan kampus masih dilakukan secara informal melalui media sosial, grup WhatsApp, atau laporan verbal kepada petugas keamanan. Pendekatan ini memiliki beberapa kelemahan kritis:

1. **Tidak ada mekanisme verifikasi kepemilikan** — siapa pun dapat mengklaim barang tanpa bukti yang terstruktur.
2. **Data sensitif pengguna tidak terlindungi** — informasi kontak dan identitas tersebar tanpa enkripsi.
3. **Tidak ada jejak audit (audit trail)** — tidak ada catatan siapa yang mengakses informasi barang kapan dan dari mana.
4. **Akses tidak terdiferensiasi** — tidak ada pembedaan hak akses antara mahasiswa umum, civitas akademika, dan administrator.

Proyek ini hadir sebagai solusi berbasis web yang tidak hanya mendigitalisasi proses lost & found, tetapi juga menerapkan protokol keamanan informasi secara menyeluruh, menjadikannya sebagai studi kasus implementasi nyata prinsip-prinsip keamanan informasi dalam lingkungan akademik.

## 2. Deskripsi Sistem

**Nama Sistem** : Lost & Found IPB

**Jenis Aplikasi**: RESTful Web API + Web Client

**Deskripsi**:

Sistem Lost & Found IPB adalah platform berbasis web yang memfasilitasi pelaporan dan pencarian barang hilang/temuan di lingkungan kampus IPB University. Sistem ini dirancang dengan pendekatan *security-by-design*, di mana protokol keamanan informasi ditanamkan sejak tahap arsitektur, bukan sebagai tambahan setelah pengembangan.

### 2.1 Fitur Utama

|                                |                                                                                                       |
|--------------------------------|-------------------------------------------------------------------------------------------------------|
|                                |                                                                                                       |
| <b>Pelaporan Barang Hilang</b> | Pengguna terautentikasi dapat melaporkan barang yang hilang beserta detail, foto, dan lokasi kejadian |

|                                |                                                                                      |
|--------------------------------|--------------------------------------------------------------------------------------|
| <b>Pelaporan Barang Temuan</b> | Pengguna dapat melaporkan barang yang ditemukan di lingkungan kampus                 |
| <b>Pencarian &amp; Filter</b>  | Pencarian barang berdasarkan jenis laporan, lokasi, dan tanggal kejadian             |
| <b>Klaim Kepemilikan</b>       | Mekanisme klaim terstruktur dengan bukti teks dan foto untuk memvalidasi kepemilikan |
| <b>Review Klaim</b>            | Administrator memverifikasi klaim dan menentukan status persetujuan                  |
| <b>Manajemen Pengguna</b>      | Registrasi, autentikasi, dan manajemen profil dengan diferensiasi peran              |

## 2.2 Peran Pengguna

| SISTEM LOST & FOUND IPB                                                              |                                                                                                                                                    |                                                                                                                                                                       |
|--------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| UMUM                                                                                 | CIVITAS AKADEMIKA                                                                                                                                  | ADMIN                                                                                                                                                                 |
| <ul style="list-style-type: none"> <li>• Lihat item</li> <li>• Registrasi</li> </ul> | <ul style="list-style-type: none"> <li>• Semua hak UMUM</li> <li>• Laporkan item</li> <li>• Ajukan klaim</li> <li>• Lihat klaim sendiri</li> </ul> | <ul style="list-style-type: none"> <li>• Semua hak CIVITAS</li> <li>• Review &amp; approve klaim</li> <li>• Manajemen pengguna</li> <li>• Akses log sistem</li> </ul> |

Deteksi peran Civitas dilakukan otomatis berdasarkan domain email `@ipb.ac.id` atau `@apps.ipb.ac.id`.

## 3. Identifikasi Aset

Identifikasi aset merupakan langkah pertama dalam manajemen risiko keamanan informasi. Berikut adalah aset-aset kritis yang dimiliki sistem:

### 3.1 Aset Informasi (Data)

|      |                                            |                |               |                             |
|------|--------------------------------------------|----------------|---------------|-----------------------------|
|      |                                            |                |               |                             |
| A-01 | Kredensial Pengguna (email, password hash) | <b>RAHASIA</b> | Sangat Tinggi | Database <code>users</code> |

|      |                                            |                |               |                                             |
|------|--------------------------------------------|----------------|---------------|---------------------------------------------|
| A-02 | Data Profil Pengguna (nama lengkap, peran) | INTERNAL       | Tinggi        | Database <code>users</code>                 |
| A-03 | Foto Bukti Klaim                           | INTERNAL       | Tinggi        | Filesystem<br><code>/storage/claims/</code> |
| A-04 | Data Barang Hilang/Temuan                  | PUBLIK         | Sedang        | Database <code>items</code>                 |
| A-05 | Riwayat Klaim & Status Review              | INTERNAL       | Tinggi        | Database <code>claim</code>                 |
| A-06 | JWT Access Token                           | <b>RAHASIA</b> | Sangat Tinggi | Client-side (Header)                        |
| A-07 | Secret Key Aplikasi                        | <b>RAHASIA</b> | Sangat Tinggi | Environment Variable                        |
| A-08 | Foto Barang                                | PUBLIK         | Rendah        | Filesystem<br><code>/storage/items/</code>  |

### 3.2 Aset Perangkat Lunak

|      |                                      |                                       |
|------|--------------------------------------|---------------------------------------|
|      |                                      |                                       |
| A-09 | Backend FastAPI                      | Logika bisnis dan endpoint API        |
| A-10 | Database PostgreSQL                  | Penyimpanan data persisten            |
| A-11 | Modul <code>digital_signature</code> | Implementasi autentikasi dan keamanan |
| A-12 | Alembic Migration                    | Pengelolaan skema database            |

### 3.3 Aset Infrastruktur

|      |                  |                               |
|------|------------------|-------------------------------|
|      |                  |                               |
| A-13 | Docker Container | Isolasi lingkungan runtime    |
| A-14 | Koneksi Database | Saluran komunikasi backend-DB |
| A-15 | Endpoint API     | Titik masuk layanan eksternal |

## 4. Analisis Ancaman dan Kerentanan

## 4.1 Threat Modeling menggunakan STRIDE

|                        |                                            |            |        |
|------------------------|--------------------------------------------|------------|--------|
|                        |                                            |            |        |
| Spoofing               | Penyerang meniru identitas pengguna lain   | A-01, A-06 | TINGGI |
| Tampering              | Manipulasi data klaim atau status review   | A-05       | SEDANG |
| Repudiation            | Pengguna menyangkal telah mengajukan klaim | A-05       | SEDANG |
| Information Disclosure | Kebocoran data pribadi pengguna            | A-01, A-02 | TINGGI |
| Denial of Service      | Banjir permintaan ke endpoint API          | A-09, A-15 | SEDANG |
| Elevation of Privilege | Pengguna biasa mengakses fungsi admin      | A-05       | TINGGI |

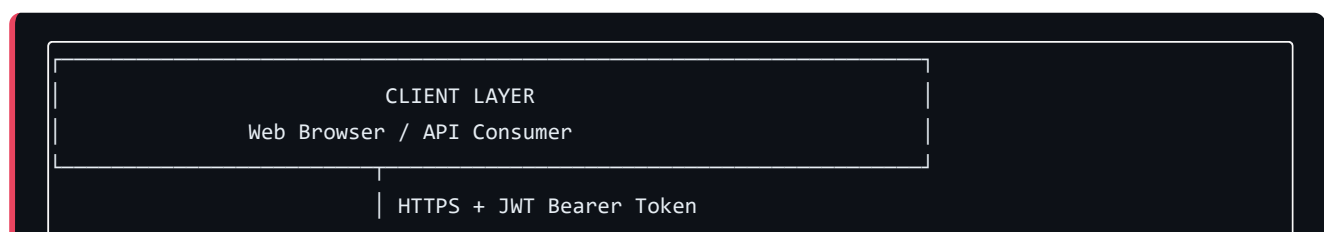
## 4.2 Kerentanan Sistem Existing

Berdasarkan analisis terhadap sistem pelaporan manual yang ada saat ini:

1. **Penyimpanan password plaintext** — tidak ada mekanisme hashing.
2. **Tidak ada autentikasi berbasis token** — sesi login tidak tervalidasi secara kriptografis.
3. **Tidak ada kontrol akses berbasis peran** — semua orang dapat mengakses semua data.
4. **Tidak ada validasi bukti klaim** — proses klaim tidak terstruktur.
5. **Tidak ada audit trail** — tidak ada pencatatan aktivitas pengguna.

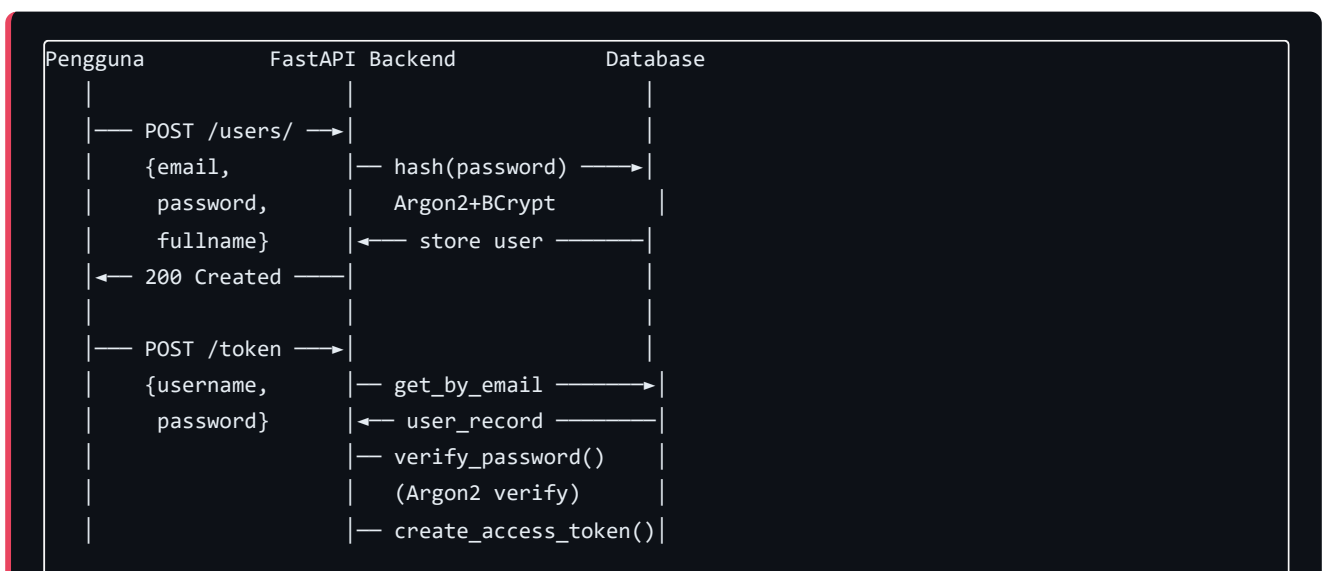
# 5. Arsitektur Keamanan yang Diusulkan

## 5.1 Arsitektur Sistem Keseluruhan



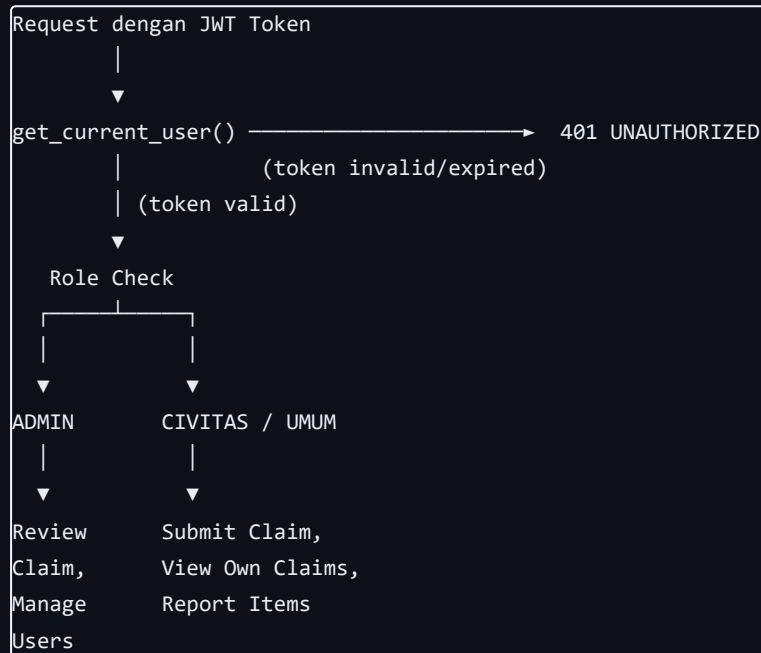


## 5.2 Alur Autentikasi (Authentication Flow)





### 5.3 Alur Otorisasi Berbasis Peran (Authorization Flow)



## 6. Modul Kriptografi

### 6.1 Password Hashing (Modul: `digital_signature/utils.py` )

Sistem menggunakan `passlib` dengan skema kriptografi berlapis:

|                    |                                                         |
|--------------------|---------------------------------------------------------|
|                    |                                                         |
| Algoritma Utama    | Argon2 (Argon2id)                                       |
| Algoritma Fallback | bcrypt_sha256, bcrypt                                   |
| Library            | <code>passlib[bcrypt]</code> , <code>argon2-cffi</code> |

|              |                                                             |
|--------------|-------------------------------------------------------------|
| Implementasi | CryptContext(schemes=["argon2", "bcrypt_sha256", "bcrypt"]) |
|--------------|-------------------------------------------------------------|

### Justifikasi Pemilihan Argon2:

- Pemenang Password Hashing Competition (PHC) 2015
- Resistensi terhadap serangan GPU dan ASIC
- Dapat dikonfigurasi: memory cost, time cost, parallelism
- Rekomendasi OWASP untuk penyimpanan password modern

## 6.2 Manajemen Token JWT (JSON Web Token)

|                    |                                                 |
|--------------------|-------------------------------------------------|
|                    |                                                 |
| Algoritma Signing  | HMAC-SHA256 (HS256)                             |
| Library            | python-jose[cryptography]                       |
| Masa Berlaku Token | 60 menit (access token)                         |
| Payload Klaim      | sub (email), exp (expiry)                       |
| Secret Key         | Disimpan di environment variable ( SECRET_KEY ) |

### Skema JWT yang Digunakan:

```
Header: {"alg": "HS256", "typ": "JWT"}
Payload: {"sub": "user@ipb.ac.id", "exp": <timestamp>}
Signature: HMAC-SHA256(base64(header) + "." + base64(payload), SECRET_KEY)
```

## 6.3 Proteksi Secret Key

Secret key dan konfigurasi sensitif **TIDAK pernah di-commit** ke repositori. Dikelola melalui:

```
# .env (masuk .gitignore)
DATABASE_URL=postgresql+asyncpg://user:pass@localhost/dbname
SECRET_KEY=<random-256-bit-secret>
ALGORITHM=HS256
ACCESS_TOKEN_EXPIRE_MINUTES=60
CLAIM_UPLOAD_DIR=backend/storage/claims
```

## 7. Stack Teknologi

|                  |                       |                |                               |
|------------------|-----------------------|----------------|-------------------------------|
|                  |                       |                |                               |
| API Framework    | FastAPI               | 0.115.0        | RESTful API, async support    |
| ASGI Server      | Uvicorn               | 0.30.6         | HTTP server                   |
| ORM              | SQLAlchemy            | 2.0.35         | Database abstraction (async)  |
| Database         | PostgreSQL            | Latest         | Penyimpanan data relasional   |
| DB Driver        | asyncpg               | 0.31.0         | Async PostgreSQL driver       |
| Migrasi DB       | Alembic               | 1.13.2         | Schema versioning             |
| Password Hashing | passlib + argon2-cffi | 1.7.4 / 23.1.0 | Hashing & verifikasi password |
| JWT              | python-jose           | 3.5.0          | Token generation & validation |
| Validasi Data    | Pydantic              | 2.9.2          | Schema validation             |
| Konfigurasi      | pydantic-settings     | 2.5.2          | Environment-based config      |
| Containerization | Docker + Compose      | Latest         | Deployment & isolasi          |

## 8. Rencana Implementasi

### Milestone Pengembangan

|     |                        |                                                                      |
|-----|------------------------|----------------------------------------------------------------------|
|     |                        |                                                                      |
| 1-2 | Inisiasi & Analisis    | Proposal Teknis, Analisis Kerentanan Sistem Lama                     |
| 3-4 | Desain Sistem          | ERD, Diagram Arsitektur, Rencana Pengujian                           |
| 5   | Coding Sprint I        | API CRUD dasar: Users, Items                                         |
| 6   | Implementasi Auth      | JWT, Password Hashing (Argon2), Modul <code>digital_signature</code> |
| 7   | Monitoring P7          | Laporan Kemajuan Bab 1-3, Demo Video                                 |
| 8-9 | Asymmetric & Signature | Fitur tanda tangan digital untuk non-repudiation                     |

|       |                       |                                                       |
|-------|-----------------------|-------------------------------------------------------|
| 10    | Security Update       | Password Hashing, Role-based Access Control           |
| 11-12 | AAA Protocol          | Authentication + Authorization + Accounting (Logging) |
| 13    | Integration & Testing | End-to-end testing, unit test modul keamanan          |
| 14-15 | Final Release         | Paper Ilmiah, User Manual, Aplikasi Stabil            |

## 8.1 Struktur Repositori Target

```

keamanan-informasi-pbl/
├── 01_Proposal_&_Analisis/
│   ├── Proposal_Teknis.md      ← Dokumen ini
│   └── Threat_Modeling.pdf
├── 02_Design_Documents/
│   ├── ERD_Modified.png
│   ├── Architecture_Diagram.pdf
│   └── Testing_Plan.pdf
├── 03_Source_Code/
│   ├── backend/                ← FastAPI app, routers, domains
│   ├── database/              ← ORM models, session
│   └── digital_signature/      ← Auth, JWT, hashing, non-repudiation
├── 04_Reports_&_Paper/
│   ├── Monitoring_P7/
│   ├── Final_Technical_Report/
│   └── Scientific_Paper/
└── README.md

```

## 9. Tim Pengembang

| (Nama Anggota 1) | (NIM) | Project Lead / Backend | backend/app/ , main.py            |
|------------------|-------|------------------------|-----------------------------------|
| (Nama Anggota 2) | (NIM) | Security Engineer      | digital_signature/ , JWT, Hashing |
| (Nama Anggota 3) | (NIM) | Database Engineer      | database/ , Alembic Migration     |
| (Nama Anggota 4) | (NIM) | Backend Developer      | backend/app/domains/ , Services   |
| (Nama Anggota 5) | (NIM) | Dokumentasi & Testing  | Testing, Paper, Laporan           |

**Catatan** : Seluruh anggota tim diwajibkan melakukan commit individual pada bagian kode yang menjadi tanggung jawabnya untuk membuktikan kontribusi dalam evaluasi

*aktivitas Git.*

## Referensi

1. OWASP Top 10 Web Application Security Risks (2021)
2. NIST SP 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management
3. RFC 7519: JSON Web Token (JWT)
4. Argon2 Password Hashing Competition — <https://www.password-hashing.net/>
5. FastAPI Security Documentation — <https://fastapi.tiangolo.com/tutorial/security/>
6. STRIDE Threat Modeling — Microsoft Security Development Lifecycle

*Dokumen ini merupakan luaran Pertemuan 1-2 dari mata kuliah Keamanan Informasi (KOM1315), Program Studi Ilmu Komputer, IPB University, Semester Genap 2025/2026.*